Monthly Intelligence Dispatch

September 2021

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly overview by Group-IB, an international company that specializes in the prevention of cyberthreats and the development of information security products. The objective of the Dispatch is to inform readers about the current cyberthreats, attacks by criminal groups, data leaks, and new malware. This report includes news of arrests and legal actions against members of hacker groups, as well as short-term forecasts and warnings that will help you take timely measures to protect yourself against cyberthreats. Group-IB's MTID is prepared for in-house use only and is not intended for wide distribution.

Key findings

- On September 28, 2021, Group-IB CEO Ilya Sachkov was detained in Moscow. An official statement by the company.
- Group-IB confirmed that The Bell website was hacked and a fake mass email was sent on September 2.
- Twitch streaming platform has suffered a massive leak affecting many of its users. 4chan published a torrent link to a file that is 125 GB in size.
- In August and September 2021, Group-IB discovered more than 100 suspicious domains with names that included the words bankpay and paybank. Resources masquerading as money transfer systems are aiming to steal billing data from Russian citizens.
- Analysts at Group-IB's Digital Risk Protection (DRP) Department have detected a fraud scheme targeting users in Arabic-speaking countries in Africa and the Middle East.
- After ProtonMail gave the police the IP addresses and device information a Youth for Climate green movement activist used to access his email account, leading to his arrest, there were many questions about the email service's actions.
- According to Group-IB, in 2021 the number of attacks on companies and organizations in Russia has increased by more than 200%.
- Former Cardplanet operator Alexey Burkov has been deported to Russia from the United States.

Ilya Sachkov

On September 28, 2021, Group-IB CEO Ilya Sachkov was detained in Moscow. On the same day, the police searched one of the company's Moscow offices in connection with the investigation. Operations at Group-IB's other Russian or international offices were not disrupted. The company continues to provide services to customers and partners as normal in all the regions of its presence.

Note that a criminal case was filed only against Ilya Sachkov, while law enforcement agencies have no complaints about other Group-IB employees or the company itself.

From September 29, 2021, the position of Group-IB CEO will be held by Dmitry Volkov, the company's second co-founder and Chief Technology Officer. In this position, Dmitry will be responsible for implementing the company's strategic plans of entering international markets and strengthening Group-IB's position in its current markets.

Security of customer data is a top priority for Group-IB. We have built our geographically distributed infrastructure to ensure 24/7 security of customer data and operability of all Group-IB services, as well as critical business processes at our Russian and international offices.

We would like to take this opportunity to thank our customers and partners once again for their understanding and support. We urge everyone to interpret the news in a judicious manner: the case materials are closed from the public, which gives rise to a lot of unreliable or inaccurate information, rumors and speculation.

Rosgeologiya

Group-IB revealed that a cyberattack was attempted on the Russian geological exploration holding company Rosgeologiya, presumably perpetrated by a foreign government. In March 2021, the THF system detected a suspicious instance of access to Rosgeologiya's secure perimeter, and data were transmitted to the CERT-GIB. Group-IB employees determined that cybercriminals had penetrated the mail server and were attempting to run malware. Having received the necessary information about the attack, Rosgeologiya's security service quickly localized and eliminated the threat. As a reminder, about 100,000 companies and organizations around the world fell victim to an attack using a zero-day vulnerability in Microsoft Exchange Server mail servers in the spring of 2021. By authenticating on a server, attackers succeeded in gaining administrator rights, installing malware, and stealing data. At first, such attacks were carried out by Hafnium, a foreign APT group, and later other hacker groups, such as LuckyMouse, Tick and IronTiger, began to use this method of attack.

Twitch

A magnet link (used by peer-to-peer systems and torrents) was published on the anonymous message board 4chan to download a 125 GB archive. According to the source, the archive contains a huge amount of data related to the Twitch.tv streaming platform. The poster proclaimed this archive contains just the first part of the database but did not specify whether the second part would be published or offered for sale and what data it would include. The first part of the archive, according to the source, contains the source codes for more than 6000 internal GIT repositories. Unfortunately, only Twitch itself can confirm the authenticity of these data. If we assume that the platform user data have not been published, the main threat to all will be the emergence of the platform "clones". Threat actors will be doing this to collect real user data. The purpose of the attack is to confuse users and make them think that they are on a legitimate page of the platform. After this, users may enter their usernames and passwords, which will be delivered directly to the threat actors. Also, hackers may try to collect phone or credit card information from such websites. For these reasons, you should be very careful to make sure that you enter your password on a legitimate website. In addition to websites, mobile apps can be subjected to similar attacks.

The Bell

The Group-IB's Digital Forensics Lab confirmed that unidentified persons had gained unauthorized access to the admin panel of www.thebell.io. The Lab has established the circumstances of the September 2, 2021 incident, when threat actors sent a fake newsletter containing inflammatory content on behalf of The Bell.

The investigation revealed that on August 29 from 19:01 to 19:57 (UTC +8), attackers sent queries indicating they were attempting to exploit a vulnerability that allowed remote code execution. Between August 30, 17:40 (UTC +8) and August 31, 10:15 (UTC +8), The Bell website was actively scanned using Burp Suite software, a tool designed, among other things, to check for vulnerabilities in web applications.

"On August 30, 2021, attackers gained access to the administrative console of the www.thebell.io website, allowing them to carry out an unauthorized mailing on September 2, 2021," the report states. Group-IB employees emphasize that any further investigation would require the involvement of law enforcement agencies. On September 13, 2021, The Bell filed a complaint with the police at the Arbat District Department of the Russian Ministry of Internal Affairs. The Bell may hand over the investigation findings by Group-IB experts to law enforcement agencies.

ProtonMail

The security of the ProtonMail mail service, which for a long time was considered the most reliable way to transmit confidential data and has been known as "email for the paranoid," has once again been called into question, The Register reports. After ProtonMail gave the police the IP addresses and device information that a Youth for Climate green movement activist used to access his email account, which led to his arrest, there were many questions about the email service's actions.

Blogspot

In the spring of 2021, Group-IB analysts from the Digital Risk Protection (DRP) department detected a fraudulent scheme targeting users in Arabic-speaking countries in Africa and the Middle East. In their attacks, threat actors illegally used more than **130** well-known global brands from various industries: telecommunications, retail, entertainment industry, etc. In total, Group-IB analysts discovered more than **4,300** fraudulent pages created on Blogspot, a popular blogging platform. All these pages were registered by a group of more than 100 accounts. The scammers adopted a proven method, using as bait giveaway contests purportedly organized by famous brands, cash prize draws allegedly run by celebrities, and fake competitive calls for job applications from government agencies.

bankpay

In August and September 2021, Group-IB discovered more than **100** suspicious domains with names that included the words bankpay and paybank. Resources masquerading as money transfer systems are aiming to steal billing data from Russian citizens. https://bankpay-ds[.]ru is a classic example of a website on such a domain (the resource has been blocked). A footer on the website says that it is a "government-operated payment system", but the Bank of Russia license details are "borrowed" from a well-known payment system, although for the sake of respectability the date of registration was "aged" by three years, and the registered address provided is not real. This web resource and a network of two dozen more domain names were created to collect logins and passwords, which will then, in the best case scenario, be added to the databases of publicly leaked data, ending up in the hands of phone scam operators. The user enters data on the website to make a money transfer, and all the information ends up in the hands of the threat actors.

Ransomware

According to Group-IB, in 2021 the number of attacks on companies and organizations in Russia has increased by more than 200%. The amount of the ransom requested from Russian companies, as a rule, depends on the size of the organization. The average ransom paid in 2021 amounted to USD 42,300. The average downtime of an attacked company was 18 days. According to the survey, 27.4% of Russian entrepreneurs have been subjected to cyberattacks over the past two years. Over half of surveyed businesspeople (50.9%) consider the threat of ransomware to be dangerous, and about the same number (51.9%) believe that their company is "fairly unprotected" from attacks by ransomware. Interestingly, 77.4% of Russian small and medium-sized businesses surveyed by The Bell were "not at all in a position to pay" cybercriminals to decrypt data if they were attacked by ransomware. At the same time, 33% of entrepreneurs said that downtime of even a few hours would be critical for their business, and another 30% said that a day-long downtime would be critical.

Badbot

In the first half of 2021, the proportion of internet traffic generated by malicious bots reached 39%. Russia belongs to the top five countries by the number of IP addresses from which unwanted traffic originates, said Pavel Krylov, head of online fraud prevention at Group-IB. In August 2021, bot traffic for DDoS attacks in Russia increased tenfold compared to other months. "Bad" bots steal unique proprietary content from websites, infiltrate personal accounts by collecting confidential user information, leave thousands of spam comments and fake reviews, and can even shut down a website by generating countless queries. Bad bot traffic poses a threat to all online services, regardless of the industry: while previously malicious bots more often threatened online stores and marketplaces, recently experts have been observing their activity in the energy industry, housing and utility services, healthcare, education, and entertainment sectors.

Arrests and sentences

Alexey Burkov

Alexey Burkov, a Russian citizen and owner of two bank card fraud websites, Cardplanet and Direct Connection, who had been sentenced to nine years in prison in the United States, was deported back to Russia. He was found guilty of manufacturing and selling counterfeit bank cards as well as trafficking in banking customers' confidential data. An investigation established that the illegal acts were committed between 2008 and 2015. Detained at the Ben-Gurion Airport at the request of the U.S. authorities in 2015, in the fall of 2018 Burkov was extradited from Israel to the U.S. In the intervening years, the Russian authorities tried to exchange Alexey Burkov for Naama Issachar, an Israeli citizen sentenced in Russia to seven and a half years in prison on drug smuggling charges, and when the plan failed and Burkov was extradited to the United States, the Russian embassy in Washington sent a protest note to the US Department of State.

Mars

The U.S. Department of Justice reported that 28-year-old Ukrainian citizen Gleb Ivanov-Tolpintsev was extradited from Poland. He was accused of selling access to hacked computer systems through a specialized darknet marketplace. According to court documents, the suspect had been running a botnet for more than four years while using it to conduct bruteforce attacks. Ivanov-Tolpintsev bruteforced, hacked, and sold approximately 2,000 credentials per week. Under the nickname *Mars*, he sold access to 6,704 computers pocketing USD 82,648.

Ransomware

A joint special operation by the Ukrainian police, Interpol, Europol and the FBI was conducted in Kiev, involving seven raids and two arrests on suspicion of extortion using encryption software. The detainees are assumed to be members of a criminal group that has been attacking major companies in Europe and North America since April 2020. More than 100 organizations have been affected by the actions of this cybergroup, with the total damage estimated at USD 150 million. In addition to deploying malware, the hackers steal information and threaten to release it if a ransom is not paid.
To introduce a cryptolocker into a network, threat actors conduct targeted mailings or hack a remote access service on a computer. According to Europol, threat actors demand between EUR 5 million and 70 million from their victims as payment for the decryption key.

Forecasts and warnings

- According to Group-IB, in the first half of 2021, there were almost three times as many attacks on critical infrastructure facilities in Russia as in the whole of 2019. The Group-IB THF solution can help organizations stop targeted attacks and track down the perpetrators. By protecting large industrial facilities, THF allows to eliminate the costs associated with downtime due to a cyberattack and optimize the spending by partially automating incident response and investigation tasks.
- The publication of the entirety of the Twitch database has become a very serious problem for the entire online community. Even though there are no passwords in this database, it still carries a significant threat. Threat actors will be able to conduct targeted malicious mailouts, which can result in a huge amount of damage, from data theft to the encryption lock of an entire device.
- 50% of Russian entrepreneurs surveyed know that in 40-60% of all the cases cybercriminals penetrate the systems via email. At the same time, an equal proportion, 50%, do not use additional email protection technologies, limiting themselves to the built-in security capabilities. About 16% give no thought at all to the protection of their email. Seemingly harmless emails sent by hackers are the most common way to gain access to a corporate network.
  As a rule, this is followed by malware downloads, data encryption, spying, or theft of money, resulting in business paralysis for an indefinite period of time. In recent years, both large corporations and small companies have been subjected to attacks.
- Over the past few years, along with an increase in user activity, there has been a significant increase in traffic generated by malicious bots. The pandemic intensified these trends as it forced many people to move their customary activities online. "Good bots" help us order food, buy tickets online, send packages and obtain useful information from our Internet searches.

If you would like to receive more detailed information about a specific incident, threat, or criminal group, please contact us.

We conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+1 917 809 47 41
+7 495 984 33 64
intelligence@group-ib.com